**Полыга. Тема: Разработка интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений**

| № | Противоречия между | Задачи исследования | Результаты исследования |
|---|---|---|---|
| *Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)* | | | |
| 1 | существующим информационным обеспечением проектной деятельности по управлению рисками инфраструктуры контейнеризации Kubernetes и необходимостью его совершенствования в части сбора и обработки исходных данных для риск-анализа, а также установления соответствий между угрозами компрометации контейнерных приложений, тактиками и техниками MITRE ATT&CK, эксплуатируемыми уязвимостями CVE и компенсационными мерами защиты | Создание информационного обеспечения, покрывающего потребности проектной деятельности работы в исходных данных для риск-анализа и в формализации угроз компрометации контейнерных приложений: сбор и обработка статистики эксплуатации уязвимостей CVE компонентов кластера из открытых баз данных уязвимостей, частот успешного применения компенсационных мер и нарушений конфиденциальности, целостности и доступности по открытым интернет-источникам, событий журналов аудита кластера Kubernetes, а также формализация сценариев атак в виде цепочек тактических звеньев «тактика – техника MITRE ATT&CK – уязвимость CVE» и соответствующих им компенсационных мер | Необходимое и достаточное для решения задач работы информационное обеспечение проактивных действий по защите инфраструктуры контейнеризации Kubernetes: массив исходных данных для риск-анализа (критичность уязвимостей CVE, частоты успешного применения компенсационных мер и нарушений конфиденциальности, целостности и доступности, события журналов аудита кластера), дерево угроз и индуцированных рисков, база соответствий «шаблон атаки CAPEC – тактика – техника MITRE ATT&CK – уязвимость CVE – компенсационная мера» и граф сценариев атак на компоненты кластера Kubernetes |
| 2 | существующими методиками риск-анализа инфраструктуры контейнеризации Kubernetes и необходимостью их совершенствования в части проактивной оценки вероятности и ущерба реализации сценариев атак по каждому тактическому звену с учётом вклада отдельных компонентов кластера в общий ресурс защищаемой системы | Создание на основе сформированного информационного обеспечения аналитики проактивного риск-анализа нарушений ИБ инфраструктуры контейнеризации Kubernetes, учитывая вероятности успешного применения техник MITRE ATT&CK для эксплуатации уязвимостей CVE, ущерб от нарушения конфиденциальности, целостности и доступности информации и долю ресурса кластера, затрагиваемую эксплуатацией каждой уязвимости | Аналитическое обеспечение проактивной оценки рисков нарушения ИБ инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений: методика расчёта риска сценария атаки по его тактическим звеньям, методика оценки ущерба через компонентацию ресурса кластера и риск-ландшафт кластера Kubernetes |
| 3 | существующими методиками управления рисками нарушения ИБ инфраструктуры контейнеризации Kubernetes и необходимостью их совершенствования в части подбора компенсационных мер, снижающих вероятность эксплуатации уязвимостей и величину ущерба в тактических звеньях сценариев атак, с учётом роли компонентов кластера в распространении компрометации | Создание на основе сформированного информационного обеспечения аналитики проактивного управления рисками нарушения ИБ инфраструктуры контейнеризации Kubernetes, предусматривающей компенсационные меры снижения вероятности и ущерба в каждом тактическом звене сценария атаки, выбор мер по максимуму коэффициента смягчения риска и первоочередную защиту уязвимостей, через которые проходит наибольшее число сценариев | Аналитическое обеспечение проактивной регулировки рисков нарушения ИБ инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений: методика выбора компенсационных мер, расчёт остаточного риска и эффекта риск-регулирования, регламенты реагирования и ликвидации последствий по этапам MITRE ATT&CK |
| 4 | имеющимися средствами автоматизации оценки и регулирования рисков инфраструктуры контейнеризации Kubernetes и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части сквозного расчёта рисков сценариев атак до и после применения компенсационных мер | Формирование средств автоматизации, заточенных под проактивный экспресс-анализ процессов оценки и регулирования рисков нарушения ИБ инфраструктуры контейнеризации Kubernetes для оценки эффективности предлагаемых мер защиты, с применением методов машинного обучения в качестве вспомогательного инструмента для предварительной оценки критичности недостатков конфигурации рабочих нагрузок, не имеющих идентификатора CVE | Средства автоматизации предложенных методик оценки и регулирования рисков нарушения ИБ инфраструктуры контейнеризации Kubernetes. Оценка эффективности разработанных мер защиты кластера Kubernetes по снижению риска сценариев атак |

**Полыга. Тема: Разработка интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений**

| № | Новизна результатов | Практическая ценность результатов | Теоретическая ценность результатов |
|---|---|---|---|
| *Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)* | | | |
| 1 | Предлагаемое информационное обеспечение проектной деятельности, в отличие от аналогов, формируется на собранной и обработанной в работе статистике (критичность уязвимостей, частоты успешного применения компенсационных мер и нарушений конфиденциальности, целостности и доступности, события журналов аудита кластера) и обеспечивает сквозную привязку угроз компрометации контейнерных приложений к тактическим звеньям сценариев атак, эксплуатируемым в них уязвимостям CVE компонентов кластера (API-сервера, kubelet, среды выполнения контейнеров) и компенсационным мерам с учётом недостатков конфигурации рабочих нагрузок, делающих эти уязвимости эксплуатируемыми | Структура и состав предложенного информационного обеспечения ИБ-деятельности на объекте могут быть практически использованы в качестве источника исходных данных для расчёта рисков, при построении графа сценариев атак и выборе мер защиты инфраструктуры контейнеризации Kubernetes | Методики сбора и обработки данных, предложенные в работе, могут быть развиты применительно к иным платформам оркестрации контейнеров и облачным средам |
| 2 | Разработанная аналитика риск-анализа нарушений ИБ на объекте, в отличие от аналогов, учитывает ущерб от сценария атаки через критичность эксплуатируемых уязвимостей и долю ресурса каждого компонента кластера (плоскости управления, узлов, рабочих нагрузок), а также удельные ущербы от нарушения конфиденциальности, целостности и доступности | На практике предложенные методики риск-анализа позволяют выделять наиболее вероятные и наиболее ущербные сценарии атак на кластер Kubernetes до их реализации и сравнивать их по ущербу для отдельных компонентов кластера | Разработанные методики риск-анализа целесообразно развить в части учёта взаимного влияния компонентов кластера и мультикластерных сред |
| 3 | Разработанная аналитика управления ИБ-рисками на объекте, в отличие от аналогов, предусматривает компенсацию вероятности и ущерба в каждом тактическом звене сценария, выбор мер по максимуму коэффициента смягчения, рассчитанного по частоте успешного применения меры, и первоочередную защиту узлов графа сценариев, через которые компрометация контейнерного приложения распространяется на плоскость управления кластера | Практическое применение предложенной аналитики управления ИБ-рисками видится в обосновании выбора и очерёдности внедрения мер защиты инфраструктуры контейнеризации Kubernetes при ограниченных ресурсах на их внедрение | Перспективное развитие предложенной аналитики управления ИБ-рисками видится в расширении состава компенсационных мер и учёте мер уровня среды выполнения контейнеров |
| 4 | Созданные средства автоматизации проектной ИБ-деятельности на объекте, в отличие от аналогов, позволяют выполнять полный цикл от построения графа сценариев атак по данным CVE и MITRE ATT&CK до расчёта первичного и остаточного риска, а вспомогательная модель машинного обучения дополняет исходные данные оценками критичности недостатков конфигурации манифестов рабочих нагрузок | Созданные средства автоматизации проектной ИБ-деятельности на объекте практически необходимы для регулярного пересчёта рисков кластера Kubernetes при изменении его конфигурации | Теоретическая значимость созданного инструментария автоматизации проектной ИБ-деятельности видится в возможности его адаптации для иных платформ оркестрации контейнеров и классов угроз |

**Ковалев. Тема: Разработка интеллектуальной системы регулирования рисков корпоративной системы управления доступом при компрометации учётных записей**

| № | Противоречия между | Задачи исследования | Результаты исследования |
|---|---|---|---|
| *Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)* | | | |
| 1 | существующим информационным обеспечением проектной деятельности по управлению рисками корпоративной системы управления доступом и необходимостью его совершенствования в части сбора и обработки исходных данных для риск-анализа, а также установления соответствий между угрозами компрометации учётных записей, тактиками и техниками MITRE ATT&CK, эксплуатируемыми уязвимостями CVE и компенсационными мерами защиты | Создание информационного обеспечения, покрывающего потребности проектной деятельности работы в исходных данных для риск-анализа и в формализации угроз компрометации учётных записей: сбор и обработка статистики эксплуатации уязвимостей CVE служб каталогов и протоколов аутентификации из открытых баз данных уязвимостей, частот успешного применения компенсационных мер и нарушений конфиденциальности, целостности и доступности по открытым интернет-источникам, событий журналов аутентификации и доступа, а также формализация сценариев атак в виде цепочек тактических звеньев «тактика – техника MITRE ATT&CK – уязвимость CVE» и соответствующих им компенсационных мер | Необходимое и достаточное для решения задач работы информационное обеспечение проактивных действий по защите корпоративной системы управления доступом: массив исходных данных для риск-анализа (критичность уязвимостей CVE, частоты успешного применения компенсационных мер и нарушений конфиденциальности, целостности и доступности, события журналов аутентификации и доступа), дерево угроз и индуцированных рисков, база соответствий «шаблон атаки CAPEC – тактика – техника MITRE ATT&CK – уязвимость CVE – компенсационная мера» и граф сценариев атак на компоненты системы управления доступом |
| 2 | существующими методиками риск-анализа корпоративной системы управления доступом и необходимостью их совершенствования в части проактивной оценки вероятности и ущерба реализации сценариев атак по каждому тактическому звену с учётом выбора злоумышленником наиболее выгодных для него путей компрометации учётных записей и повышения привилегий | Создание на основе сформированного информационного обеспечения аналитики проактивного риск-анализа нарушений ИБ корпоративной системы управления доступом, учитывая вероятности успешного применения техник MITRE ATT&CK для эксплуатации уязвимостей CVE, ущерб от нарушения конфиденциальности, целостности и доступности информации и противоборство злоумышленника и защитника, формализованное в виде антагонистической игры | Аналитическое обеспечение проактивной оценки рисков нарушения ИБ корпоративной системы управления доступом при компрометации учётных записей: методика расчёта риска сценария атаки по его тактическим звеньям, теоретико-игровая модель противоборства злоумышленника и защитника с платёжной матрицей рисков сценариев и риск-ландшафт системы управления доступом |
| 3 | существующими методиками управления рисками нарушения ИБ корпоративной системы управления доступом и необходимостью их совершенствования в части подбора компенсационных мер, снижающих вероятность эксплуатации уязвимостей и величину ущерба в тактических звеньях сценариев атак, с учётом перехода злоумышленника к обходным сценариям после внедрения мер защиты | Создание на основе сформированного информационного обеспечения аналитики проактивного управления рисками нарушения ИБ корпоративной системы управления доступом, предусматривающей компенсационные меры снижения вероятности и ущерба в каждом тактическом звене сценария атаки, выбор мер по максимуму коэффициента смягчения риска и первоочередную защиту уязвимостей, через которые проходит наибольшее число сценариев | Аналитическое обеспечение проактивной регулировки рисков нарушения ИБ корпоративной системы управления доступом при компрометации учётных записей: методика выбора компенсационных мер, расчёт остаточного риска и эффекта риск-регулирования, регламенты реагирования и ликвидации последствий по этапам MITRE ATT&CK |
| 4 | имеющимися средствами автоматизации оценки и регулирования рисков корпоративной системы управления доступом и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части сквозного расчёта рисков сценариев атак до и после применения компенсационных мер | Формирование средств автоматизации, заточенных под проактивный экспресс-анализ процессов оценки и регулирования рисков нарушения ИБ корпоративной системы управления доступом для оценки эффективности предлагаемых мер защиты, с применением методов машинного обучения в качестве вспомогательного инструмента для выявления аномального накопления полномочий учётных записей при формировании исходных данных | Средства автоматизации предложенных методик оценки и регулирования рисков нарушения ИБ корпоративной системы управления доступом. Оценка эффективности разработанных мер защиты системы управления доступом по снижению риска сценариев атак |

**Ковалев. Тема: Разработка интеллектуальной системы регулирования рисков корпоративной системы управления доступом при компрометации учётных записей**

| № | Новизна результатов | Практическая ценность результатов | Теоретическая ценность результатов |
|---|---|---|---|
| *Глава 1. Исследование аналогов и постановка задач работы (противоречие и задача не формулируются)* | | | |
| 1 | Предлагаемое информационное обеспечение проектной деятельности, в отличие от аналогов, формируется на собранной и обработанной в работе статистике (критичность уязвимостей, частоты успешного применения компенсационных мер и нарушений конфиденциальности, целостности и доступности, события журналов аутентификации и доступа) и обеспечивает сквозную привязку угроз компрометации учётных записей к тактическим звеньям сценариев атак, эксплуатируемым в них уязвимостям CVE служб каталогов и протоколов аутентификации и компенсационным мерам с учётом ролей, групп и накопленных полномочий учётных записей | Структура и состав предложенного информационного обеспечения ИБ-деятельности на объекте могут быть практически использованы в качестве источника исходных данных для расчёта рисков, при построении графа сценариев атак и выборе мер защиты корпоративной системы управления доступом | Методики сбора и обработки данных, предложенные в работе, могут быть развиты применительно к сервисным и машинным идентичностям и федеративному доступу |
| 2 | Разработанная аналитика риск-анализа нарушений ИБ на объекте, в отличие от аналогов, учитывает активное противодействие злоумышленника, представляя сценарии компрометации учётных записей и повышения привилегий его стратегиями, наборы компенсационных мер — стратегиями защитника, а риски сценариев — элементами платёжной матрицы игры | На практике предложенные методики риск-анализа позволяют выделять наиболее вероятные и наиболее ущербные сценарии атак на корпоративную систему управления доступом до их реализации и определять учётные записи, компрометация которых наиболее выгодна злоумышленнику | Разработанные методики риск-анализа целесообразно развить в части учёта иных классов угроз и новых способов подтверждения личности |
| 3 | Разработанная аналитика управления ИБ-рисками на объекте, в отличие от аналогов, предусматривает выбор компенсационных мер как оптимальной стратегии защитника по минимаксному критерию остаточного риска с учётом перехода злоумышленника к обходным сценариям, а также первоочередную защиту учётных записей и уязвимостей, через которые проходит наибольшее число сценариев повышения привилегий | Практическое применение предложенной аналитики управления ИБ-рисками видится в обосновании выбора и очерёдности внедрения мер защиты корпоративной системы управления доступом, устойчивого к смене злоумышленником сценария атаки | Перспективное развитие предложенной аналитики управления ИБ-рисками видится в переходе к многошаговым и неантагонистическим играм злоумышленника и защитника, учитывающим поэтапное развитие атаки по тактическим звеньям сценария |
| 4 | Созданные средства автоматизации проектной ИБ-деятельности на объекте, в отличие от аналогов, позволяют выполнять полный цикл от построения графа сценариев атак по данным CVE и MITRE ATT&CK до расчёта первичного и остаточного риска, а вспомогательная модель машинного обучения выделяет учётные записи с аномальным накоплением полномочий как вероятные точки входа сценариев атак | Созданные средства автоматизации проектной ИБ-деятельности на объекте практически необходимы для регулярной переоценки рисков корпоративной системы управления доступом при изменении состава учётных записей и полномочий | Теоретическая значимость созданного инструментария автоматизации проектной ИБ-деятельности видится в возможности его адаптации для систем управления доступом с иными моделями разграничения прав |